

Gillsoft AB

Org.nr 556974-3098

Hammarbybacken 27, 120 30 Stockholm

info@gillsoft.se

Justitiekanslern

Box 2308

103 17 Stockholm

registrator@justitiekanslern.se

2026-05-05

Ärende: Bemötande av Finansinspektionens yttrande i ärende om skadeståndsanspråk enligt Francovich-principen — statens ansvar för Finansinspektionens bristande tillämpning av DORA-förordningen (EU) 2022/2554

1. Inledning

Gillsoft AB har tagit del av Finansinspektionens (FI) yttrande av den 5 maj 2026 i ovan rubricerade ärende. Bolaget får härmed bemöta yttrandet och återropa ytterligare dokumentation till stöd för de omständigheter som tidigare anförts i den ursprungliga skrivelsen av den 25 februari 2026.

Skrivelsen syftar till att bemöta FI:s yttrande och återropa dokumentation till stöd för redan anförda omständigheter. Skrivelsens innehåll utgör direkta bemötanden av yttrandets argument samt tolkningsförtydliganden av redan återopad rättslig grund — inte introduktion av nya yrkanden. Den återopade dokumentationen avser omständigheter som Finansinspektionen redan har kännedom om genom sin egen befattning med ärendet och föranleder därmed inte någon ny yttrandeomgång.

2. Position till Finansinspektionens yttrande

2.1 Gillsoft AB:s rättsliga ställning och oberoende av yttrandet

Den oberoende rättsdogmatiska analys som ligger till grund för Gillsoft AB:s ursprungliga skrivelse är upprättad kronologiskt före FI:s yttrande. Analysen utgör en uppsats i rättsvetenskap författad av Niklas Gillström vid Uppsala universitet, under handledning av en docent vid juridiska fakulteten med tidigare tjänstgöring som ämnesråd vid Finansdepartementets finansmarknadsavdelning. Handledaren har bedömt uppsatsens slutsatser och avslutande reflektioner som befogade. Uppsatsen är upprättad inom ramen för akademisk examination vid Uppsala universitet och är därmed institutionellt oberoende av Gillsoft AB:s verksamhet. Den fullständiga uppsatsen återfinns i bilaga 1.

Gillsoft AB är Swish Premium-partner hos Getswish AB med direktkontakt och prioriterad hantering, Swish-slutanvändare, samt teknisk leverantör till företagskunder med tjänsten Swish utbetalning hos sin bank. Bolaget har inget kontraktsmässigt arrangemang med någon medlemsbank eller med Getswish AB i den IKT-tjänsteleveransroll som regleras i artiklarna 28–30 i DORA-förordningen. Bolaget faller därmed inte inom definitionen av tredjepartsleverantör av IKT-tjänster enligt artikel

3.19. I Swish-infrastrukturen utgörs den IKT-tredjepartsleverantörsroll som artikel 3.19 reglerar av Getswish AB självt — eller, beroende på klassificering, av en koncernintern leverantör enligt artikel 3.20.

Bolagets rättighetsgrund under unionsrätten följer av samverkande bestämmelser. Skäl 8 i DORA-förordningen anger uttryckligen att förordningen syftar till att skydda slutanvändare av finansiella tjänster. Gillsoft AB är som Swish-slut användare en sådan skyddad slut användare, oberoende av bolagets parallella ställning som teknisk leverantör i Swish-ekosystemet. Skäl 31 och 63 i DORA-förordningen utvidgar förordningens regim till koncerninterna och externa leverantörer enligt samma riskhanteringskrav, vilket dokumenterar att skyddsändamålet verkar i en bredare krets än enbart de direkt reglerade finansiella entiteterna. GDPR (förordning 2016/679) artikel 5(1)(c) stadgar uppgiftsminimering vid behandling av personuppgifter — Niklas Gillström som privatperson omfattas direkt av detta skydd vid Swish-transaktioner där hans transaktionsdata behandlas i betalningskedjan. Brasserie du Pêcheur-kriteriet att "den överträdde rättsregeln ska vara avsedd att skapa rättigheter för enskilda" är därmed uppfyllt på flera samverkande grunder.

2.2 Bemötande av yttrandets kärnargument

Gillsoft AB noterar att Finansinspektionens yttrande inte besvarar den specifika fråga som ställts om huruvida myndighetens tillsynsmetod säkerställer efterlevnad av DORA-förordningens krav på verifiering av kryptografisk nyckelhantering. Yttrandets allmänna hänvisning till olika tillsynsmetoder utan precisering av vilken metod som faktiskt verifierar HSM-efterlevnad hos finansiella entiteters kunder innebär att den underliggande tillsynsbristen kvarstår oadresserad. Frånvaron av materiellt svar utgör i sig dokumentation av att verifiering enligt förordningens krav inte ingår i myndighetens etablerade tillsynspraxis.

Frånvaron av materiellt svar är dessutom anmärkningsvärd i ljuset av Finansinspektionens egen position i remissvaret av den 13 april 2026 (FI dnr 26–3005) avseende kompletterande bestämmelser till EU:s cyberresiliensförordning. I det remissvaret bedömer myndigheten att "de föreslagna åtgärderna överlag är väl avvägda och skapar förutsättningar för utvecklingen av säkra produkter med digitala element genom att bidra till att de hårdvaru- och programvaruprodukter som släpps ut på marknaden har färre sårbarheter och att tillverkarna tar säkerheten på allvar under produktens hela livscykel." De tillstyrkta åtgärderna inkluderar materiell tillsynsmetodik gentemot tillverkare. När samma myndighet inom kort tidsavstånd tillstyrker materiella åtgärder under en regulatorisk regim men avstår från eller motsätter sig motsvarande materiell verifiering under DORA-tillsynen, uppstår en differens i tillsynsmetodik mellan två angränsande regulatoriska kontexter som båda syftar till digital operativ motståndskraft. Frånvaron av redovisning för denna differens är i sig en del av tillsynsbristen.

Inkonsekvensen är ytterligare anmärkningsvärd givet att referensimplementationer som adresserar verifieringsmekanism, kontrollmekanism och avvecklingsspärr är fritt tillgängliga under MIT-licens med obefintliga utvecklingskostnader i förhållande till utveckling från grunden och utan upphandlingsförfarande. Den faktiska implementeringströskeln för materiell DORA-tillsyn är låg, vilket gör frånvaron av sådan tillsyn svårare att förklara med hänvisning till resursrelaterade hinder.

2.3 Underbyggnad genom dokumenterad bevisning

Finansinspektionens yttrande beskriver anmälan dnr 25-2410 som att anmälaren ansåg det vara "ett absolut krav" att HSM-kontroll utförs. Bilaga 6 i den ursprungliga skrivelsen av den 25 februari 2026 (anmälan av den 22 januari 2025) redovisar dock betydligt mer substansrik information: namngivna samtliga tio banker (sex ägarbanker och fyra deltagarbanker) som erbjuder Swish utbetalning, branschpositionerad empirisk bekräftelse att samtliga utom en aktör saknar HSM-bunden nyckelhantering, riskklassificeringen "systemhotande", specifika tekniska lösningsförslag avseende HSM-attesteringscertifikat vid CSR-utfärdande med implementeringstajmning, samt dokumenterad bekräftelse av Getswish AB:s ovilja att införa kontroll. Förvaltningsrättens utredningsplikt avseende underlag av denna substans är inte beroende av avsändarens identitet.

Anmälan dnr 25-2410 redovisar därutöver direkt citat ur Swish-avtalets punkt 5.2.2: "Kunden förbinder sig till att hantera den privata nyckeln på ett säkert sätt, i HSM (Hardware Security Module) eller motsvarande." Medlemsbankerna har därmed avtalsmässig kunskap om HSM-kravet och har, genom det gemensamma ägandet av Getswish AB, strukturella förutsättningar att verifiera att kravet uppfylls. DORA-förordningens artikel 28.5 förutsätter att kontraktsmässiga arrangemang får ingås endast med tredjepartsleverantörer som uppfyller lämpliga standarder för informationssäkerhet, vilket implicerar verifiering av att kraven faktiskt efterlevs. Finansinspektionens tillsynspraxis avseende denna specifika kontroll — om medlemsbankerna verifierar att deras egna kontrakterade krav uppfylls — redovisas inte i yttrandet.

Den dokumenterade kombinationen — bankernas egna avtalskrav på HSM, DORA-förordningens motsvarande verifieringskrav, anmälan dnr 25-2410:s redovisning att samtliga utom en aktör i Swish-infrastrukturen saknat HSM-bunden nyckelhantering under tre års tid, samt Finansinspektionens yttrandeförda frånvaro av redovisad verifiering — utgör en systematisk och pågående överträdelse av direkt tillämplig unionsrätt. Överträdelsens omfattning (samtliga tio banker (sex ägarbanker och fyra deltagarbanker) som erbjuder Swish utbetalning och deras företagskunder med tjänsten), varaktighet (tre år) och karaktär (avseende klart specificerade förordningskrav som Finansinspektionen själv citerar i sitt yttrande) uppfyller Brasserie du Pêcheur-kriteriet om tillräckligt klar överträdelse med betydande marginal.

Finansinspektionens yttrande citerar artikel 7 i RTS 2024/1774, som ålägger finansiella entiteter att "genomföra kontroller för att skydda de kryptografiska nycklarna" och att upprätthålla "ett register [...] över alla certifikat och certifikatslagringsenheter för åtminstone de IKT-tillgångar som stöder entitetens kritiska och viktiga funktioner". Finansinspektionen redovisar dock inte i sitt yttrande om eller hur myndigheten verifierar att finansiella entiteter genomför dessa specifika kontroller. Avsaknaden av sådan redovisning är inte en bevisrättslig osäkerhet utan ett konstaterande att en sådan verifiering inte föreligger för den period skadeståndsanspråket avser. Annars hade myndigheten haft alla skäl att framlägga den till sitt försvar i sitt yttrande till Justitiekanslern.

3. Precisering av rättslig grund — kravet på strukturellt oberoende verifiering

Den ursprungliga skrivelsen åberopar artiklarna 5, 6.10, 9 och 28 i DORA-förordningen som rättslig grund för verifieringskravet. Gillsoft AB preciserar härmed att en systematisk läsning av dessa redan åberopade artiklar — i kombination med de strukturella oberoendekraven i artiklarna 6.4 och 6.6 som följer av samma artikelfamilj — visar att verifieringen enligt artikel 6.10 förutsätter strukturellt oberoende mellan utfärdande och verifierande entitet. Denna precisering utvidgar inte den åberopade rättsliga grunden utan klargör tolkningen av de redan åberopade bestämmelserna.

Förordningen behandlar koncerninterna och externa leverantörer enligt samma riskhanteringskrav (skäl 31) och utvidgar uttryckligen definitionen av tredjepartsleverantörer av IKT-tjänster i artikel 3.19 till koncerninterna leverantörer (skäl 63). Klassificeringen av GetSwish AB som koncernintern leverantör eller tredjepartsleverantör enligt artiklarna 3.19 och 3.20 påverkar därmed inte slutsatsen — kontrollkraven är desamma. Skäl 30 dokumenterar att unionslagstiftaren har identifierat en specifik brist i nationell tillsyn som DORA-förordningen är avsedd att åtgärda, vilket är centralt för förståelsen av förordningens räckvidd.

3.1 Artiklarna 6.4 och 6.6 — krav på strukturellt oberoende

Artikel 6.4 ålägger finansiella entiteter att säkerställa lämplig åtskillnad och oberoende för riskhanteringsfunktioner och kontrollfunktioner enligt modellen med tre försvarslinjer eller motsvarande intern kontrollmodell. Artikel 6.6 kräver att interna revisorer ska ha lämplig nivå av oberoende. Bestämmelserna etablerar att DORA-förordningens hela kontrollstruktur vilar på strukturellt oberoende mellan funktioner som utför, kontrollerar och granskar IKT-relaterad verksamhet.

Verifiering av efterlevnad enligt artikel 6.10 är en kontrollfunktion i förordningens mening. När verifieringen utförs av en entitet under samma ägarskap som den finansiella entitet vars efterlevnad ska kontrolleras, elimineras den oberoende dimension som artiklarna 6.4 och 6.6 förutsätter för kontrollstrukturens funktion.

3.2 Artikel 28.4 — skyldighet att identifiera intressekonflikter

Artikel 28.4 e ålägger finansiella entiteter att innan de ingår kontraktsmässiga arrangemang om användning av IKT-tjänster identifiera och bedöma intressekonflikter som arrangemanget kan orsaka. När en bank ingår avtal om verifieringstjänster med en koncernintern aktör enligt artikel 3.20, är intressekonflikten strukturellt given genom det gemensamma ägandet. Bestämmelsen förutsätter att finansiella entiteter dokumenterat hanterar denna intressekonflikt, vilket inte är möjligt utan att verifieringsfunktionen separeras strukturellt från det gemensamma ägandet.

3.3 Sammanfattande slutsats om strukturella förutsättningar

Den systematiska läsningen av artiklarna 3.20, 6.4, 6.6, 6.10 och 28.4 jämte skälen 8, 30, 31 och 63 visar att DORA-förordningen inte enbart kräver att verifiering sker, utan att verifieringen sker genom en mekanism som strukturellt är oberoende av den finansiella entitet vars efterlevnad kontrolleras. För svensk Swish-infrastruktur innebär detta att verifiering genom GetSwish AB inte uppfyller förordningens oberoendekrav, eftersom GetSwish AB ägs gemensamt av sex ägarbanker (Danske

Bank, Handelsbanken, Länsförsäkringar Bank, Nordea, SEB och Swedbank) som är de finansiella entiteter vars efterlevnad ska kontrolleras. Tjänsten Swish utbetalning erbjuds därutöver av fyra deltagarbanker (Marginalen Bank, Northmill, Svea Bank och Sparbanken Syd) som inte äger Getswish AB. Strukturoberoende-bristen avser de sex ägarbankerna; den materiella verifieringsbristen avser samtliga tio banker. Verifieringen måste därför ske antingen genom en strukturellt oberoende extern aktör (teknisk leverantör utanför ägarstrukturen) eller genom en mekanism som strukturellt eliminerar det gemensamma ägandets påverkan på verifieringsfunktionen.

Tillsynsbristen manifesterar sig härmed i två dimensioner som båda faller inom myndighetens tillsynsansvar enligt DORA-förordningen: dels att FI:s tillsynspraxis inte säkerställer att finansiella entiteter materiellt verifierar att signeringsnycklar lagras i certifierad HSM-hårdvara enligt avtalsvillkoren, dels att FI:s tillsynspraxis inte säkerställer att de strukturella förutsättningarna för oberoende verifiering är uppfyllda. Att FI saknar dokumenterad bedömning av frågan om strukturellt oberoende utgör en separat tillsynsbrist från den materiella verifieringen, eftersom de strukturella förutsättningarna för verifieringen är en självständig kontrollnivå enligt förordningens tillsynsstruktur.

Skäl 12 preciserar att DORA-förordningen genomför ett metodologiskt skifte från traditionell kvantitativ riskhantering till riktade kvalitativa regler avseende skydd, upptäckt, begränsning, återställning och avhjälpande av IKT-relaterade incidenter. Förordningens kvalitativa tillsynsregler avser konkret skydd, upptäckt, begränsning, återställning och avhjälpande — inte enbart kartläggning av ramverk och processer genom enkäter. Materiell verifiering av kryptografisk nyckelhantering är en sådan riktad kvalitativ kontroll som faller inom förordningens uppgraderade tillsynsmetod. Finansinspektionen har själv i sin publikation av den 2 juni 2025 (<https://www.fi.se/sv/publicerat/nyheter/2025/fi-granskar-den-finansiella-sektorns-digitala-operativa-motstandskraft/>) redovisat att den fördjupade analysen av DORA-implementeringen genomförs i tre etapper genom "tre separata enkäter" hos 50 utvalda finansiella företag. Enkätbaserade kartläggningar av huruvida finansiella entiteter har "ramverk" eller "processer" motsvarar varken den traditionella kvantitativa metoden (kapitalkrav) eller den nya riktade kvalitativa metoden som förordningen förutsätter.

Slutsatsen förstärks av Finansinspektionens egna interna styrdokument. Tillsynsstrategin (FI dnr 22-24464, beslutad den 31 oktober 2022, bilaga 5) gör en uttrycklig distinktion mellan fördjupade analyser och undersökningar. Fördjupade analyser beskrivs som "bred kartläggning av en enskild risk eller en analys av hur ett eller flera företag följer eller förhåller sig till en viss bestämmelse", medan undersökningar utgör enligt strategin tillsynens främsta verktyg för att kommunicera bedömningar om avvikelser från regelverket till enskilda aktörer. Fördjupad analys kan enligt Tillsynsstrategin ge underlag för beslut om undersökning. Undersökningsprocessen (FI dnr 25-17423, beslutad den 18 juni 2025, bilaga 6) bekräftar att FI:s formaliserade undersökningsmetod inkluderar materiell informationsinsamling, platsbesök och faktagranskning som standardelement.

Finansinspektionens hittills publicerade tillsynsåtgärder avseende DORA-implementeringen utgörs av enkätbaserade fördjupade analyser, inte undersökningar. Att fördjupade analyser inte har följts av undersökning av frågan om HSM-bunden nyckelhantering — trots att frågan dokumenterats vid flera

tillfällen från januari 2025 — innebär att den materiella verifiering som DORA-förordningens artikel 9.4 d och RTS 2024/1774 artikel 7 förutsätter inte har realiserats genom FI:s tillsyn.

Finansinspektionen åberopar i sitt yttrande att myndigheten tillämpar en riskbaserad tillsynsmetod i enlighet med globala standarder såsom FATF och Basel-ramverket. Riskbaserad tillsyn är emellertid inte ekvivalent med obegränsad diskretion. Enligt EU-domstolens praxis i *Brasserie du Pêcheur* (mål C-46/93 och C-48/93, punkt 56) minskar utrymmet för skönsmässig bedömning i takt med att den unionsrättsliga regelns klarhet och precision ökar. DORA-förordningens artikel 9 är på flera punkter klar och precis: artikel 9.1 ålägger finansiella entiteter att "kontinuerligt övervaka och kontrollera IKT-systemens och IKT-verktygens säkerhet och funktion"; artikel 9.3 c stadgar att IKT-lösningar ska "förhindra bristen på tillgänglighet, försvagandet av äkthet och integritet, överträdelserna av konfidentialitet, och förlusten av data"; artikel 9.3 d stadgar att IKT-lösningar ska "säkerställa att uppgifterna skyddas mot risker som uppstår från datahanteringen, inbegripet bristfällig förvaltning, processrelaterade risker och den mänskliga faktorn"; och artikel 9.4 d kräver uttryckligen "strategier och protokoll för starka äkthetsmekanismer, baserade på relevanta standarder och särskilda kontrollsystem, samt skyddsåtgärder för kryptografiska nycklar".

Sammantaget formulerar artikel 9 ett krav på att kryptografiska nycklar ska skyddas genom mekanismer som eliminerar risker från mänsklig hantering — vilket är HSM-teknikens specifika funktion: nyckeln genereras inom HSM-enheten, kan inte exporteras, och är därmed otillgänglig för mänsklig åtkomst. HSM utgör den tekniska realiseringen av artikel 9.3 d:s skydds krav mot "den mänskliga faktorn" tillämpat på kryptografiska nycklar. Att Finansinspektionen tillämpar en generisk riskbaserad tillsynsmetod utesluter inte skyldigheten att specifikt verifiera dessa kontroller, vilka artikel 7 i RTS 2024/1774 — vilken Finansinspektionen själv citerar i sitt yttrande — preciserar för kryptografiska nycklar "för hela deras livscykel, från generering till förstörelse". Riskbaserad tillsyn kompletterar specifika verifieringskrav, ersätter dem inte.

Tillsynens funktion enligt DORA-förordningen är att förebygga incidenter, inte att enbart rapportera och analysera dem efter att de inträffat. Detta följer direkt av förordningens namn — Digital Operational Resilience Act — där operativ motståndskraft är ett preventivt koncept, samt av artikel 9.1:s krav på "kontinuerlig övervakning och kontroll". En tillsynspraxis som enbart består i efterhandsanalys av inrapporterade data realiserar inte förordningens preventiva syfte.

4. Verkställbarhetsarkitektur och bevisbördevändning

Den materiella tillsyn som DORA-förordningens artiklar 6.4, 6.6, 6.10, 9 och 28.4 e föreskriver är inte beroende av nya rättsliga instrument eller protokollförändringar. Den kan implementeras inom befintliga svenska tillsyns- och avvecklingsstrukturer genom triangulering över fyra oberoende datakällor:

- (i) Tilldelningsregistret hos Getswish AB över aktiva utbetalnings-nummer för tjänsten Swish utbetalning,

(ii) audit-loggen i Finansinspektionens egen kontrollinstans (referensimplementationen *gatekeeper*) över HSM-attesterade certifikatutfärdanden,

(iii) Riksbankens RIX-INST-logg över genomförda eller avvisade avvecklingar för Swish utbetalning, samt

(iv) den mottagna betalningens registrering i Swish-infrastrukturen och hos mottagarens bank — eftersom mottagaren av Swish utbetalning per definition är privatperson kan transaktionen by-design verifieras oberoende av sändarsidans rapportering.

Triangulering över de fyra källorna identifierar varje icke-compliant transaktion strukturellt. Verifieringen sker kryptografiskt deterministiskt på transaktionens hash-värde — inte på dess innehåll — vilket innebär att tillsynsuppgiften kan utföras utan att tillsynsmyndigheten erhåller affärs- eller transaktionssensitiv information. Detta gör arkitekturen förenlig med GDPR-förordningens uppgiftsminimerings-princip och med DORA-förordningens proportionalitetskrav vid tillsynsdatabehandling. Ingen av datakällorna kräver ny lagstiftning eller protokollförändring; samtliga finns att tillgå inom Finansinspektionens befogenheter enligt DORA-förordningens artiklar 28 och 32.

Den fjärde datakällans externa verifierbarhet följer av tjänstens kommersiella natur — banken kan inte tillhandahålla Swish utbetalning utan att producera spårbar mottagarregistrering, eftersom utebliven mottagarregistrering innebär att tjänsten inte levererats. Compliance-arkitekturen är därmed strukturellt självförstärkande av tjänstens definition.

Referensimplementationerna *hsm* (DOI: <https://doi.org/10.5281/zenodo.19930310>) och *gatekeeper* (DOI: <https://doi.org/10.5281/zenodo.19930395>) samt *railgate* (DOI: <https://doi.org/10.5281/zenodo.19952991>) demonstrerar konkret att verifieringsmekanismen, kontrollmekanismen och avvecklingsspärren är operationaliserbara inom dessa förutsättningar. Samtliga tre är publicerade under MIT-licens, deponerade på Zenodo med permanenta DOI-länkar, och har obefintliga utvecklingskostnader i förhållande till utveckling från grunden samt kräver inget upphandlingsförfarande för att driftsättas hos Finansinspektionen respektive Sveriges Riksbank.

Finansinspektionens yttrande av den 5 maj 2026 redovisar emellertid inte någon implementerad eller planerad tillsynsprocess som motsvarar denna eller någon strukturellt likvärdig arkitektur. Yttrandet beskriver inte vilken kompletthetskontroll FI utövar mot tilldelade utbetalnings-nummer för Swish utbetalning, vilken verifieringsprocess FI tillämpar för HSM-attesting vid certifikatutfärdande, hur FI granskar strukturoberoende mellan certifikatutfärdare, signaturverifierare och finansiella entiteter, eller om FI utövat tillsyn över Getswish AB i denna specifika dimension under den tidsperiod som ärendet avser.

Frånvaron av en sådan redogörelse är inte en bevismässig osäkerhet utan ett faktiskt konstaterande att processen inte föreligger för den period skadeståndsanspråket avser. Annars hade myndigheten haft alla skäl att framlägga den till sitt försvar i sitt yttrande till Justitiekanslern.

Skadeståndsanspråkets specificitet följer härav: Finansinspektionen har inte utövat den materiella tillsyn som DORA-regelverket kräver, trots att en konkret implementeringsväg har funnits tillgänglig

under hela den period som anspråket avser. Skadan har därmed direkt orsakats av Finansinspektionens underlåtenhet — inte av regulatorisk omöjlighet eller bristande tekniska förutsättningar.

5. Åberopad bevisning för redan anförda omständigheter

Den ursprungliga skrivelsen redovisar i punkt 4 att Gillsoft AB har underrättat Finansinspektionen och Finansdepartementet om tillsynsbristen genom flera skrivelser, samt att myndigheterna efter att ha tagit del av materialet aktivt valt att inte vidta åtgärder. Skrivelsen redovisar också i punkt 6 ett skadeståndsanspråk om sammanlagt cirka 352 000 SEK avseende HSM-investering och åtgärds kostnader. Gillsoft AB åberopar härmed ytterligare dokumentation till stöd för dessa redan anförda omständigheter, avseende såväl de finansiella beloppen som de kommunikativa åtgärder som föranlett skadan.

5.1 Verifikationskedja för det yrkade skadebeloppet

Det yrkade skadebeloppet baseras på tre kostnadsposter som var och en är dokumenterad genom faktura och motsvarande betalningsverifikation från Skandinaviska Enskilda Banken AB. De exakta växelkurserna och transaktionsverifikationerna framgår av bilaga 2.

HSM-hårdvara och underhåll: Securosys SA, faktura 42467 av den 18 juli 2025, Primus HSM CyberVault Pro samt premiumunderhåll, totalt 23 563,08 EUR. Betalat av Gillsoft AB den 29 juli 2025 med 264 723,97 SEK enligt SEB:s transaktionsverifikation.

RFC3161 Timestamp-licens: Securosys SA, faktura 42490 av den 14 augusti 2025, RFC3161 Timestamp License samt premiumunderhåll, totalt 2 354,40 EUR. Betalat av Gillsoft AB den 28 augusti 2025 med 26 264,01 SEK enligt SEB:s transaktionsverifikation.

Åtgärds kostnad — publicering: Breaking Media AB, faktura 12011 av den 1 april 2025, native-artikel publicerad i Breakit den 10 mars 2025, 75 000 SEK exklusive moms. Betalat av Gillsoft AB den 2 april 2025 med 93 750 SEK inklusive moms enligt SEB:s transaktionsverifikation. Det yrkade beloppet motsvarar fakturans nettobelopp då Gillsoft AB som momsregistrerat bolag har dragit av den ingående momsen.

De faktiska betalningarna uppgår sammanlagt till 365 988 SEK efter momsavdrag, vilket något överstiger det ursprungligen yrkade beloppet om cirka 352 000 SEK. Skillnaden beror på växelkursvariationer mellan tidpunkten för Securosys-betalningarna i juli och augusti 2025 och den växelkurs som tillämpades vid skrivelsens framställning den 25 februari 2026. Gillsoft AB vidhåller det ursprungliga yrkandet om 352 000 SEK och överlåter åt Justitiekanslern att, om myndigheten finner det rimligt och förenligt med prövningens utfall, fastställa det exakta beloppet enligt bilagda transaktionsverifikationer.

5.2 Hänförlighet av åtgärds kostnaden till tillsynsbristen

Publiceringskostnaden om 93 750 SEK utgör åtgärds ersättning enligt skadeståndsrättens princip om att kostnader för att begränsa eller framtvunga rättelse av en pågående överträdelse är ersättningsgilla. Posten är inte ett anspråk på följdskada av tillsynsbristen i sig, utan ett anspråk på ersättning för en

konkret åtgärd som vidtogs för att framtvinga den tillsynsåtgärd som myndigheten varit skyldig att utföra på eget initiativ. Den temporala sekvens som dokumenteras nedan utgör konkret bevisning för åtgärdens nödvändighet och dess effekt på myndighetens responsförmåga.

Den 22 januari 2025 lämnade Gillsoft AB in en anmälan till Finansinspektionen (dnr 25-2410) om avsaknad av HSM-verifiering i Swish-infrastrukturen. Under perioden 22 januari till 10 mars 2025 vidtog FI inga åtgärder och avgav inget substantiellt svar.

Den 10 mars 2025 publicerade Niklas Gillström i egenskap av VD för Gillsoft AB ett inlägg på LinkedIn klockan 11:14 (<https://www.linkedin.com/feed/update/urn:li:share:7304821824142376962>) med länk till Breakit-artikel om frågan; Breakit publicerade artikeln klockan 12:03 samma dag. Inlägget innehöll explicita taggningar av Finansinspektionen och Regeringskansliet Finansdepartementet. Kommentaren i inlägget redogjorde konkret för den tekniska lösningen genom HSM-attesting vid certifikatutfärdande. Inlägget genererade enligt LinkedIns analysystem sammanlagt 3 361 visningar (se figur 2).

Niklas Gillström ✓ • Du
Grundare Gillsoft AB
1 år • Redigerat •

Swish utbetalning - information bankerna inte ger
[WIPIT AB](#)
[Cardia](#)
[Findity](#)
[Zplit Payments AB](#)
[Visma Spcs](#)
[Exor IT-Byrå AB](#)
[Froda](#)
[Northmill Bank](#)
[Nordea](#)
[Enklakassan](#)
[Handelsbanken](#)
[Swedbank](#)
[Länsförsäkringar](#)
[Danske Bank](#)
[SEB](#)
[Svea Bank](#)
[Marginalen Bank](#)
[Swish \(Getswish AB\)](#)
[Finansinspektionen](#)
[Swedsec Licensiering AB](#)
[Sparbanken Syd](#)
[Aftonbladet](#)
[Expressen](#)
[Dagens Nyheter](#)
[Svenska Dagbladet](#)
[Fortnox AB](#)
[Sveriges riksbank](#)
[Konkurrensverket](#)
[Regeringskansliet, Finansdepartementet](#)



Här är Swishreglerna som (nästan) alla företag bryter mot – och den smidiga lösningen
[breakit.se](#)

🕒 12 1 kommentar • 3 omdelningar

  Gilla  Kommentera  Omdela  Skicka

 3,361 visningar [Visa statistik](#)

Kommentera...  




Niklas Gillström Författare (redigerat) 1 år •
Grundare Gillsoft AB

Den obekväma men viktiga frågan är:
 Varför görs inget, och varför ser inte ansvariga myndigheter till att bankerna följer de krav som redan finns i förordningar och avtal?

HSM är redan ett krav enligt bankernas avtal, och det enklaste och mest kostnadseffektiva sättet att säkerställa dess användning är att kontrollera HSM vid utfärdandet av signeringscertifikat. En riktig HSM-enhet måste kunna utfärda ett attesteringscertifikat. Gäller bara Swish utbetalning.

- Attesteringscertifikat kan enkelt verifieras mot en certifikatförfrågan (CSR).
- HSM-verifiering kan göras på en publik webbsida för extern kontroll.
- Ett krav enligt DORA-förordningen (tredjepartsrisker).

Gilla | Svara | 164 visningar

Figur 1: LinkedIn-inlägget av den 10 mars 2025 (<https://www.linkedin.com/feed/update/urn:li:share:7304821824142376962>). Profilbilder för individuella användare har avlägsnats i enlighet med uppgiftsminimeringsprincipen i artikel 5.1 c i dataskyddsförordningen. Den textuella identifieringen av inläggets författare samt taggade institutioner och företag har behållits då dessa uppgifter utgör substantiell bevisning i ärendet.

Inläggets webbadress	https://www.linkedin.com/feed/update/urn:li:share:7304821824142376962
Inläggets uppläggningsdatum	10 mars 2025
Inläggets publiceringstid	11:14
Inläggets resultat	
Visningar	3 361
Profilbesökare från det här inlägget	10
Nya följare från det här inlägget	0
Reaktioner	12
Kommentarer	1
Ompubliceringar	3

Figur 2: Utdrag ur LinkedIns PostAnalytics som dokumenterar publiceringstidpunkt och räckvidd.

Den 11 mars 2025 klockan 07:25, drygt 20 timmar efter LinkedIn-publiceringen och drygt 19 timmar efter Breakit-artikeln publicering, sände Yvonne Lindell, Senior finansinspektör vid Finansinspektionen, ett svar på den ursprungliga anmälan från den 22 januari 2025 (se figur 3).

Från: Yvonne Lindell Yvonne.Lindell@fi.se
 Ämne: anmälan, dnr 25-2410
 Datum: 11 mars 2025 07:25
 Till: swishpayouts@protonmail.com

Tack för ditt mejl till Finansinspektionen (FI).
 FI:s uppdrag är i korthet att övervaka att de bolag som har tillstånd att bedriva verksamhet på finansmarknaden främst följer näringsrättsliga lagar och regler. Totalt handlar det om närmare 2 000 företag, alltifrån de stora bankerna och försäkringsbolagen till enmansföretag. FI:s tillsyn sker genom stickprov, huvudsakligen utifrån en bedömning av var behovet är som störst. Brister som vi uppmärksammas på av allmänheten underlättar vårt arbete - det är helt enkelt lättare att hitta svagheter om vi vet var vi ska leta.

Härmed tackar vi för din information till oss!

Med vänliga hälsningar

Yvonne Lindell

YVONNE LINDELL
 Senior finansinspektör/ Senior Supervisor

Finansinspektionen
 Box 7821, 103 97 Stockholm, Sweden
 Brunnsgatan 3
 Tel +46 8 408 980 00
Yvonne.Lindell@fi.se
www.fi.se

Information om hur Finansinspektionen behandlar personuppgifter finns att läsa på FI:s webbplats [fi.se/Om FI](http://fi.se/Om_FI)

Figur 3: E-postsvar från Yvonne Lindell, Senior finansinspektör Finansinspektionen, av den 11 mars 2025 klockan 07:25.

Den temporala sekvensen — sju veckors utebliven respons på den ursprungliga anmälan följt av föredraganderespons inom drygt 20 timmar efter offentlig publicering — utgör konkret bevisning för åtgärdens nödvändighet och effektivitet. Publiceringen var den åtgärd som faktiskt framtvängde myndighetens hantering av anmälan. Kostnaden är därmed direkt hänförlig till statens underlåtenhet att agera på den ursprungliga anmälan inom rimlig tid.

6. Karaktärisering av statens underlåtenhet

Den samlade dokumentation som föreligger genom den ursprungliga skrivelsen och denna skrivelse visar att statens underlåtenhet inte kan förklaras med begränsad kunskap, otydlig rättslig grund eller resursrelaterade hinder. Följande omständigheter dokumenterar underlåtenhetens karaktär:

Dokumenterad kunskap. Finansinspektionen och Finansdepartementet har genom anmälan, skrivelser och taggad publicering på LinkedIn aktivt notifierats om tillsynsbristen vid flera tillfällen från januari 2025.

Dokumenterad lösning. Den tekniska och regulatoriska lösningen har konkret presenterats för samtliga berörda institutioner genom tre deploy-klara referensimplementationer publicerade under MIT-licens och deponerade på Zenodo: hsm — verifieringsmekanism för finansiella entiteter (<https://github.com/niklasgillstrom/hsm>, DOI: <https://doi.org/10.5281/zenodo.19930310>) — och gatekeeper — kontrollmekanism för materiell tillsyn (<https://github.com/niklasgillstrom/gatekeeper>, DOI: <https://doi.org/10.5281/zenodo.19930395>) — och railgate — avvecklingsspärr för settlement-rail-enforcement (<https://github.com/niklasgillstrom/railgate>, DOI: <https://doi.org/10.5281/zenodo.19952991>). Verifieringsmekanismen har varit publikt tillgänglig som öppen källkod sedan den 23 november 2025 i github.com/gillsoftab/hsm-attestation-reference. Kontrollmekanismen har varit publikt tillgänglig sedan den 22 mars 2026 i github.com/gillsoftab/dora-attestation-gatekeeper. En vidareutvecklad version av båda mekanismerna har därefter publicerats under namnen hsm och gatekeeper hos github.com/niklasgillstrom och deponerats på Zenodo den 28 april 2026 med ovan angivna concept-DOI:er. Avvecklingsspärren (railgate) tillkom som tredje mekanism den 1 maj 2026. Den fullständiga commit-historiken är bevarad i samtliga repositorer och självständigt verifierbar genom `git log --reverse`. Lösningarna är fritt tillgängliga och kan driftsättas inom månader.

Dokumenterad rättslig grund. DORA-förordningens krav på materiell verifiering följer av en sammanhängande artikelkedja som klargörs i den ursprungliga skrivelsens punkt 3 och preciseras i punkt 3 i denna skrivelse. Det rättsliga utrymmet för alternativa tolkningar är begränsat när bestämmelserna analyseras systematiskt enligt etablerad EU-rättslig metod.

Dokumenterad reaktionsförmåga. FI:s svar inom drygt 20 timmar efter LinkedIn-publiceringen, efter sju veckors tystnad på den ursprungliga anmälan, indikerar att myndighetens prioritering har påverkats av extern synlighet snarare än av rättsliga skyldigheter. Härutöver konstateras att verifieringsmekanismen publicerades öppet redan i november 2025 och kontrollmekanismen i mars 2026 — under de följande månaderna fram till nuvarande tidpunkt har Finansinspektionen inte initierat några dokumenterade åtgärder för att etablera materiell tillsyn baserad på de då publika referensimplementationerna.

Dokumenterad medveten avgränsning av tillsynsmetod. Finansinspektionens prioriteringsdokument FI:s prioriteringar i tillsynen 2026 (FI dnr 26-1304, daterat 5 februari 2026, bilaga 4) fastställer som myndighetens DORA-tillsyn för 2026 endast åtgärden att ”särskilt analysera inrapporterade data kopplad till regelverket Digital Operational Resilience Act (Dora) för att identifiera risker och för att säkerställa en god efterlevnad av regelverket”. Materiell verifiering av kryptografisk nyckelhantering, attesteringsverifiering vid certifikatutfärdande eller strukturoberoende mellan certifikatutfärdare och verifierare är inte upptagna som prioriteringar. Att tillsynsmetoden uttryckligen avgränsas till data-analys av inrapporterad information utgör ett dokumenterat medvetet val att inte adressera materiell verifiering av kryptografisk nyckelhantering inom 2026 års verksamhetsår, oberoende av att DORA-

förordningens artikel 9.3 c kräver preventiva åtgärder snarare än efterhandsanalys av inrapporterad data.

Enligt EU-domstolens praxis — särskilt mål C-46/93 och C-48/93 (*Brasserie du Pêcheur/Factortame*) punkterna 55–56 — utgör det avgörande kriteriet för att anse en överträdelse tillräckligt klar att medlemsstaten uppenbart och allvarligt har missbedömt gränserna för sitt utrymme för skönsmässig bedömning. Bland de omständigheter som ska beaktas vid denna bedömning framhåller domstolen den överträdde regelns grad av klarhet och precision, omfattningen av det skönsmässiga utrymmet, fördragsbrottets avsiktliga eller oavsiktliga karaktär, den ursäktliga eller ousäktliga karaktären av en eventuell rättsvillfarelse samt antagandet eller upprätthållandet av nationell praxis som strider mot unionsrätten. Tillämpningen av dessa kriterier på den dokumenterade kombinationen av fullständig information, tillgänglig lösning, tydlig rättslig grund och dokumenterad reaktionsförmåga visar att Finansinspektionen uppenbart och allvarligt har missbedömt gränserna för sitt utrymme för skönsmässig bedömning vid tillsyn över direkt tillämplig unionsrätt. Den fortsatta passiviteten under perioden från januari 2025 till nuvarande tidpunkt utgör därmed ett uppenbart och varaktigt åsidosättande av en klar unionsrättslig förpliktelse, vilket uppfyller Francovich-doktrинens andra kriterium med god marginal.

7. Skadebeloppet

Som anges i punkt 5.1 vidhåller Gillsoft AB det ursprungliga yrkandet om 352 000 SEK. De bilagda transaktionsverifikationerna visar att de faktiska betalningarna uppgår till 365 988 SEK efter momsavdrag, vilket innebär att det yrkade beloppet är något lägre än den faktiska skadan. Bolaget överlåter åt Justitiekanslern att, om myndigheten finner det rimligt och förenligt med prövningens utfall, fastställa det exakta beloppet enligt verifikationerna, oavsett om denna prövning leder till justering uppåt baserat på de faktiska transaktionerna eller justering nedåt baserat på myndighetens bedömning av enskilda kostnadsposters hänförlighet till den dokumenterade tillsynsbristen.

Det yrkade beloppet är medvetet begränsat i förhållande till bolagets faktiska skada. Förlorade intäkter och utebliven vinst är inte inkluderade i anspråket. Gillsoft AB har medvetet hållit anspråket symboliskt för att möjliggöra fokuserad principiell prövning av statens skadeståndsansvar, snarare än att söka maximal ekonomisk kompensation.

Finansinspektionen bedömer i sitt yttrande att HSM-investeringen utgör "ett rent affärsmässigt beslut av bolaget som inte har något samband med FI:s verksamhet eller beslut". Bedömningen är inte korrekt. Även om Gillsoft AB inte är en finansiell entitet under DORA-förordningens direkta tillämpningsområde, är investeringen i HSM-hårdvara och RFC3161 timestamp-licens inte ett frivilligt affärsbeslut utan avtalsmässigt nödvändig.

Swish-avtalets punkt 5.2.2 — bankernas egna kundavtal som citeras i anmälan dnr 25-2410 — ålägger varje företagskund med tjänsten Swish utbetalning att hantera sin privata signeringsnyckel i HSM. Företagskunder kan uppfylla detta krav antingen genom att själva inneha HSM eller genom att anlita teknisk leverantör som tillhandahåller säker nyckelhantering i HSM. Gillsoft AB tillhandahåller den senare lösningen som teknisk leverantör till företagskunder med Swish utbetalning. För att kunna

leverera komplianta tjänster i denna roll är HSM-investeringen avtalsmässigt nödvändig och följer av det kontraktskrav som DORA-förordningens artikel 9.4 d och RTS 2024/1774 artikel 7 — vilka Finansinspektionen själv citerar i sitt yttrande — föreskriver för bankerna.

Eftersom Finansinspektionens tillsynspraxis inte verifierar att övriga tekniska leverantörer i Swish-infrastrukturen uppfyller samma avtalsmässiga och förordningsmässiga krav, har Gillsoft AB:s HSM-investering blivit kommersiellt missgynnad: kostnader bolaget burit för att uppfylla det avtalsmässiga och unionsrättsliga kravet är kostnader som konkurrerande tekniska leverantörer slipper bära så länge tillsynen inte upprätthåller kravet. Brasserie-kriteriet om direkt orsakssamband mellan överträdelsen och skadan är därmed uppfyllt med god marginal.

8. Avslutning

Gillsoft AB vidhåller skadeståndsanspråket i skrivelsen av den 25 februari 2026. Prövningen av anspråket förutsätter att Justitiekanslern tar ställning till de rättsliga frågor som denna skrivelse aktualiserar, däribland huruvida Finansinspektionens tillsynspraxis under den aktuella perioden uppfyller DORA-förordningens krav på materiell verifiering av kryptografisk nyckelhantering och på de strukturella förutsättningarna för verifieringens oberoende enligt artiklarna 3.20, 6.4, 6.6, 6.10 och 28.4 jämte skälen 8, 30, 31 och 63 i förordningen. Bolaget överlåter åt myndigheten att bedöma dessa frågor inom ramen för myndighetens prövning.

Gillsoft AB bekräftar att skrivelsen syftar till att bemöta Finansinspektionens yttrande och åberopa dokumentation till stöd för de omständigheter som anförts i den ursprungliga framställningen. Den åberopade dokumentationen avser omständigheter som Finansinspektionen redan har kännedom om genom sin egen befattning med ärendet, och föranleder därmed inte någon ny yttrandeomgång enligt förordningen om handläggning av skadeståndsanspråk mot staten.

Bolaget anser ärendet vara fullständigt utrett från sin sida och har inga ytterligare yttranden att lämna. Gillsoft AB hemställer att Justitiekanslern går vidare med sin prövning av skadeståndsanspråket på det underlag som föreligger genom den ursprungliga skrivelsen av den 25 februari 2026, Finansinspektionens yttrande och denna skrivelse av den 5 maj 2026. Om myndigheten bedömer att ytterligare underlag krävs står bolaget givetvis till förfogande för att besvara konkreta förfrågningar.

Stockholm den 2026-05-05

Niklas Gillström
VD, Gillsoft AB

Bilagor

1. Gillström, Verifieringsansvar för kryptografiska nycklar i betalinfrastruktur — En rättsdogmatisk fallstudie av kontraktuell riskallokering och DORA-förordningens krav på IKT-riskhantering.
2. Verifikationskedja för det yrkade skadebeloppet: Securosys SA, faktura nr 42467 av den 18 juli 2025 jämte SEB transaktionsverifikation av den 29 juli 2025 (264 723,97 SEK); Securosys SA, faktura nr 42490 av den 14 augusti 2025 jämte SEB transaktionsverifikation av den 28 augusti 2025 (26 264,01 SEK); samt Breaking Media AB, faktura nr 12011 av den 1 april 2025 jämte SEB transaktionsverifikation av den 2 april 2025 (93 750 SEK).
3. Finansinspektionens remissvar av den 13 april 2026 (FI dnr 26–3005) avseende kompletterande bestämmelser till EU:s cyberresiliensförordning (SOU 2025:115).
4. Finansinspektionen, FI:s prioriteringar i tillsynen 2026, FI dnr 26-1304, 5 februari 2026.
5. Finansinspektionen, Tillsynsstrategi, FI dnr 22-24464, beslutad 31 oktober 2022.
6. Finansinspektionen, Undersökningsprocessen, FI dnr 25-17423, beslutad 18 juni 2025.